

ESPRIM

École Supérieure Privée d'Ingénierie et de Technologies

RAPPORT DE WORKSHOP

Module : Sécurité Informatique

Fascicules 1 à 6 | Année universitaire 2025-2026 | 4ème Année

réalisé par : Ranime Jemal , Ibtihel Jenzri , ibtissem gasmi , Ameni Bensoussia

Fascicule 1	Préparation de l'environnement & Analyse des vulnérabilités
Fascicule 2	Attaques réseaux (ARP Spoofing, MITM, DoS, DDoS, Social Engineering)
Fascicule 3	Cryptographie avec OpenSSL
Fascicule 4	Installation et configuration de pfSense (LAN/WAN/DMZ)
Fascicule 5	IDS/IPS avec Snort & VPN avec OpenVPN
Fascicule 6	Sécurité des applications Web (OWASP / WebGoat)

Introduction Générale

Ce rapport présente une synthèse complète des six fascicules du module de Sécurité Informatique réalisés dans le cadre du workshop de 4ème année à ESPRIM (2025-2026). Ces travaux pratiques couvrent l'ensemble du cycle de sécurité : de la mise en place d'un environnement d'analyse, en passant par l'exécution d'attaques dans un cadre virtuel contrôlé, jusqu'à la mise en place de contre-mesures (firewall, IDS/IPS, VPN) et la sécurisation des applications web.

L'environnement de travail repose sur VMware Workstation Pro 17 avec deux machines virtuelles principales : Kali Linux (machine attaquante) et Metasploitable2 (machine cible), le tout dans un réseau isolé et sécurisé..

FASCICULE 1 Préparation de l'environnement & Analyse des vulnérabilités

Objectifs

- Installer VMware Workstation Pro / Player
- Installer et configurer Kali Linux
- Démarrer la VM Metasploitable2
- Réaliser un scan réseau avec Nmap
- Effectuer une analyse de vulnérabilités avec Nessus

Partie 1 — Préparation de l'environnement

La mise en place de l'environnement de travail constitue la première étape indispensable. Elle comprend l'installation de VMware Workstation (Windows) ou VMware Fusion (macOS), puis le déploiement de deux machines virtuelles :

- Kali Linux : téléchargé depuis kali.org, avec les identifiants par défaut kali/kali
- Metasploitable2 : machine intentionnellement vulnérable, téléchargée sur SourceForge

Partie 2 — Scan réseau avec Nmap

Nmap est un scanner de ports open source permettant de détecter les ports ouverts, les services hébergés et les informations sur le système d'exploitation d'une cible.

Commandes utilisées

```
nmap 192.168.20.0/24          # Scan rapide du réseau
nmap -O <IP>                  # Identification du système
d'exploitation
nmap -p- <IP>                  # Scanner tous les ports
nmap -p 22,443 192.168.20.0/24 # Vérifier l'état des ports 22
et 443
```

Partie 3 — Analyse de vulnérabilités avec Nessus

Nessus est un scanner de vulnérabilités professionnel. Son installation sur Kali Linux suit les étapes suivantes :

```
sudo dpkg -i Nessus-10.8.2-debian9_amd64.deb
systemctl start nessusd.service
systemctl status nessusd.service
```

L'interface web est accessible à l'adresse <https://kali:8834/>. Après activation avec une licence Nessus Essentials et création d'un compte administrateur, des analyses de vulnérabilités peuvent être configurées et exportées sous différents formats.

FASCICULE 2 Attaques Réseaux

Objectifs

Ce fascicule présente les principales attaques réseau simulées dans un environnement virtuel contrôlé, avec trois machines : Kali Linux (attaquante), Metasploitable2 (victime) et une machine physique Windows/Mac.

Configuration réseau

Machine	@IP/Masque	Gateway	DNS
Machine Windows	192.168.43.191/24	192.168.43.1	1.1.1.1
Kali Linux	192.168.43.230/24	192.168.43.1	1.1.1.1
Metasploitable2	192.168.43.22/24	192.168.43.1	1.1.1.1

Attaque 1 — ARP Spoofing (Usurpation d'identité)

L'attaque ARP Spoofing consiste à envoyer de fausses réponses ARP afin d'associer l'adresse MAC de l'attaquant à l'adresse IP de la passerelle dans le cache ARP de la machine victime. L'attaquant se positionne ainsi en homme du milieu (Man-in-the-Middle).

Résultat : L'adresse MAC de Kali Linux apparaît associée à l'IP de la gateway dans la table ARP de Metasploitable2.

Attaque 2 — Sniffing MITM (Man In The Middle)

À l'aide de l'outil Ettercap (disponible graphiquement sur Kali), l'attaquant intercepte les communications entre la machine victime et sa gateway. Couplé à Driftnet, il est possible de capturer les images naviguées par la victime. Le trafic HTTP non chiffré (identifiants, URLs) est entièrement visible.

Attaque 3 — TCP SYN Flooding (DoS)

Cette attaque de déni de service consiste à bombarder la machine cible de paquets TCP SYN avec une adresse IP source falsifiée et inexistante. La victime répond par SYN-ACK mais ne reçoit jamais le ACK final, ce qui épuise ses ressources réseau.

Outil utilisé : Metasploit Framework, module auxiliary/dos/tcp/synflood.

```
use auxiliary/dos/tcp/synflood
set RHOST 192.168.43.22
run
```

Attaque 4 — Smurf (DDoS)

L'attaque Smurf exploite le protocole ICMP. L'attaquant forge des paquets ICMP Echo Request avec comme adresse source l'IP de la victime et les envoie à l'adresse de broadcast du réseau. Toutes les machines du réseau répondent alors à la victime, saturant sa connexion.

Outil utilisé : Scapy (forge de paquets).

```
# Paquet IP source = victime, dest = broadcast
send(IP(src='192.168.43.22', dst='192.168.43.255')/ICMP(), loop=1)
```

Attaque 5 — Social Engineering

a) Website Phishing (Credential Harvester Attack)

À l'aide du Social Engineering Toolkit (SET), une réplique d'un site web légitime est créée. La victime y saisit ses identifiants qui sont capturés en temps réel par l'attaquant.

b) Lien piégé

Un fichier HTML malveillant (test.html) est préparé sur la machine attaquante. Lorsque la victime clique sur le lien, une charge utile est exécutée sur sa machine.

FASCICULE 3 Cryptographie avec OpenSSL

Objectifs

Ce fascicule vise à familiariser les étudiants avec les services de base de la sécurité de l'information via la suite logicielle OpenSSL : chiffrement symétrique, chiffrement asymétrique, hachage, signature numérique et certification.

1. Chiffrement Symétrique

Algorithme RC4

```
openssl enc -rc4 -in fichier_clair -out fichier_chiff_rc4
openssl enc -rc4 -d -in fichier_chiff_rc4 -out fichier_dechiff
diff fichier_clair fichier_dechiff # Vérification de l'identité
```

Algorithme DES

```
openssl enc -des -in fichier -out fichier_chiff_des -k
0123456789ABCDEF
openssl enc -des -d -in fichier_chiff_des -out fichier_dechiff
```

2. Chiffrement Asymétrique RSA

Le chiffrement asymétrique RSA utilise une paire de clés : une clé publique (chiffrement) et une clé privée (déchiffrement).

```
openssl genrsa -out rsakey.pem 1024 # Génération de la paire
de clés
openssl rsa -in rsakey.pem -pubout -out rsapubkey.pem # Extraction
clé publique
openssl enc -AES256 -in rsakey.pem -out rsakeyencaes.pem #
Chiffrement clé privée
openssl pkeyutl -pubin -inkey rsapubkey.pem -in fichier -encrypt -out
chiff.rsa
openssl pkeyutl -inkey rsakey.pem -in chiff.rsa -decrypt -out dechiff
```

3. Signature Numérique

La signature numérique garantit l'authenticité et l'intégrité d'un document. Elle consiste à chiffrer l'empreinte (hash) du document avec la clé privée de l'émetteur.

```
openssl dgst -md5 -out fichier.md5 fichier # Empreinte MD5
openssl dgst -sha1 -out fichier.sha1 fichier # Empreinte SHA1
openssl rsautl -sign -in fichier.sha1 -inkey rsakey.pem -out
fichier_sig
openssl rsautl -verify -in fichier_sig -pubin -inkey rsapubkey.pem -
out empreinte
```

4. Certificat Numérique

Un certificat numérique lie une clé publique à une identité. Deux modes sont possibles : auto-signature ou signature par une Autorité de Certification (AC).

Auto-signature

```
openssl req -new -x509 -days 365 -key serveur_cle.pem -out
serveur_cert.crt
openssl x509 -in serveur_cert.crt -text -noout
```

Signature par une AC

```
openssl genrsa -out cakey.pem 2048
openssl req -new -x509 -days 730 -key cakey.pem -out ca.crt
openssl x509 -req -in server.csr -out server.crt -CA ca.crt -CAkey
cakey.pem -CAcreateserial
```

FASCICULE 4 Installation et Configuration de pfSense

Objectifs

- Créer les adaptateurs réseau virtuels (LAN, DMZ)
- Installer pfSense sur VMware Workstation
- Configurer les interfaces WAN, LAN et DMZ
- Mettre en place des règles de pare-feu

Architecture réseau

L'architecture déployée comprend trois interfaces réseau distinctes :

Interface	Adresse IP	VMnet	Rôle
WAN (em0)	Dynamique (DHCP)	Bridge	Connexion Internet (FAI)
LAN (em1)	192.168.11.1/24	VMnet11	Réseau interne
DMZ (em2)	192.168.12.1/24	VMnet12	Serveurs exposés

Installation de pfSense

L'installation de pfSense suit les étapes suivantes dans VMware Workstation :

- Créer une VM avec 3 adaptateurs réseau (Bridge, VMnet11, VMnet12)
- Monter l'ISO pfSense-CE-2.7.2-RELEASE-amd64 et démarrer en mode installation
- Sélectionner 'Install pfSense' et utiliser le partitionnement Auto (ZFS)
- Assigner les interfaces : WAN → em0, LAN → em1, DMZ → em2

Configuration des règles de pare-feu

Les règles pfSense sont configurées depuis Firewall > Rules et suivent un ordre de priorité strict. Les types d'actions disponibles sont :

- Pass : autorise le trafic correspondant
- Block : bloque silencieusement (l'attaquant ne sait pas s'il est bloqué)
- Reject : rejette avec notification à l'émetteur

Les règles LAN vers WAN nécessitent Source = LAN Net et Destination = WAN Net. La règle Anti-Lockout (port 80/443) protège l'accès à l'interface GUI et ne peut pas être supprimée.

Port Forwarding (NAT)

La redirection de port est configurée dans Firewall > NAT > Port Forward. Elle permet de rendre un serveur interne accessible depuis l'extérieur. Exemple : redirection du port FTP 21 WAN → 192.168.168.2:21 (serveur AD).

FASCICULE 5 IDS/IPS avec Snort & VPN avec OpenVPN

Prérequis

- Architecture LAN/WAN/DMZ en place
- pfSense installé et configuré

Partie 1 — IDS/IPS avec Snort

Snort est un système de détection/prévention d'intrusion (IDS/IPS) open source intégré directement dans pfSense via le Package Manager.

Installation

Accéder à System > Package Manager > Available Packages et rechercher 'Snort'. Cliquer sur Install pour lancer l'installation.

Configuration d'une règle de détection ICMP

Une règle personnalisée est créée pour détecter le trafic ICMP sortant du LAN et générer une alerte avec le format :

```
alert icmp $HOME_NET any -> any any (msg:"2425-4SAE6-G1";  
sid:1000001; rev:1;)
```

Le rapport d'alertes peut ensuite être exporté pour analyse.

Partie 2 — VPN avec OpenVPN

OpenVPN permet d'établir un tunnel VPN chiffré entre les réseaux LAN et WAN. La configuration sur pfSense suit 7 étapes :

Étape 1 : Création de l'Autorité de Certification (AC)

Depuis System > Cert.Manager > onglet CAs : créer une AC interne avec algorithme RSA 2048 bits, digest SHA256 et une durée de validité de 10 ans (3650 jours).

Étape 2 : Création du certificat serveur

Depuis System > Cert.Manager > onglet Certificates : créer un certificat de type 'Server' signé par l'AC précédemment créée.

Étape 3 : Création d'un utilisateur local

Depuis System > User Manager > Users : créer un utilisateur avec nom d'utilisateur, mot de passe et un certificat utilisateur associé.

Étape 4 : Configuration du serveur OpenVPN

Depuis VPN > OpenVPN > Servers, les paramètres principaux sont :

- Server mode : Remote Access (SSL/TLS + User Auth)
- Backend : Local Database
- Protocol : UDP
- Interface : WAN
- Port : 1194 (recommandé de changer pour la sécurité)
- Algorithme de chiffrement : AES-256-CBC
- IPv4 Tunnel Network : 10.0.8.0/24

Étape 5 : Export de la configuration OpenVPN

Installation du package 'openvpn-client-export' depuis le Package Manager. La configuration peut ensuite être exportée en format .ovpn pour Windows, macOS, iOS ou Android.

Étapes 6 & 7 : Règles pare-feu et test de connexion

Une règle WAN est ajoutée pour autoriser le trafic UDP sur le port OpenVPN, et une règle OpenVPN est créée pour autoriser l'accès aux ressources internes. La connexion est testée en important le fichier .ovpn dans le client OpenVPN.

FASCICULE 6 Sécurité des Applications Web — OWASP / WebGoat

Objectifs

- Installer et configurer l'application web vulnérable WebGoat
- Réaliser deux attaques Web parmi les Top 10 OWASP
- Proposer des solutions et contre-mesures

Installation de WebGoat

WebGoat est une application web intentionnellement vulnérable développée par OWASP. Elle permet de pratiquer les attaques web dans un cadre légal et contrôlé.

Méthode 1 — Docker

```
docker pull webgoat/goatandwolf
docker run -p 127.0.0.1:8080:8080 -p 127.0.0.1:9090:9090 \
-e TZ=Europe/Amsterdam webgoat/webgoat
```

Méthode 2 — Package Java

Télécharger le fichier .jar depuis <https://github.com/WebGoat/WebGoat/releases> et lancer :

```
java -jar webgoat-server-8.2.2.jar
```

Top 10 OWASP — Rappel

Les attaques à réaliser sont choisies parmi les dix vulnérabilités les plus critiques des applications web selon l'OWASP :

- A01 — Broken Access Control
- A02 — Cryptographic Failures
- A03 — Injection (SQL, XSS, etc.)
- A04 — Insecure Design
- A05 — Security Misconfiguration
- A06 — Vulnerable and Outdated Components
- A07 — Identification and Authentication Failures
- A08 — Software and Data Integrity Failures
- A09 — Security Logging and Monitoring Failures
- A10 — Server-Side Request Forgery (SSRF)

Attaques à réaliser

Dans le cadre de ce fascicule, deux attaques sont sélectionnées parmi le Top 10 OWASP et réalisées sur l'environnement WebGoat. Pour chaque attaque, les captures d'écran commentées, la description de la vulnérabilité exploitée et les contre-mesures proposées sont documentées dans le rapport de workshop.

Contre-mesures et bonnes pratiques

Pour chaque vulnérabilité exploitée, des solutions doivent être proposées, notamment :

- Validation et échappement des entrées utilisateur (SQL Injection, XSS)
- Contrôle d'accès strict basé sur les rôles (RBAC)
- Chiffrement fort des données sensibles (mots de passe, données personnelles)

- Mise à jour régulière des composants et bibliothèques tierces
- Configuration sécurisée par défaut des serveurs et applications
- Journalisation et surveillance des événements de sécurité

Conclusion Générale

Ce workshop en six fascicules constitue un parcours complet de sécurité informatique, allant de l'analyse passive des vulnérabilités jusqu'à la mise en place de mécanismes de défense en profondeur. Chaque fascicule apporte une brique supplémentaire dans la construction d'une infrastructure sécurisée :

- Fascicule 1 : L'analyse préventive avec Nmap et Nessus permet d'identifier les failles avant qu'un attaquant ne les exploite.
- Fascicule 2 : La simulation d'attaques (ARP Spoofing, DoS, Social Engineering) sensibilise aux vecteurs réels d'attaque et à leur impact.
- Fascicule 3 : La cryptographie (chiffrement, signature, certificats) constitue le socle des communications sécurisées.
- Fascicule 4 : pfSense fournit une protection périmétrique avec le cloisonnement LAN/WAN/DMZ et des règles de filtrage précises.
- Fascicule 5 : Snort ajoute une couche de détection comportementale, tandis qu'OpenVPN assure la confidentialité des accès distants.
- Fascicule 6 : La sécurité applicative complète l'approche en s'attaquant aux vulnérabilités au niveau du code et de la configuration web.

L'ensemble de ces compétences forme un profil d'ingénieur capable d'appréhender la sécurité de manière holistique : anticiper les menaces, déployer des défenses adaptées, et tester l'efficacité des contre-mesures mises en place.